
TCX2005: Information Systems, Management and Organisations

L8: Securing Information Systems

Prakash C. Sukhwal (Dr.)
Senior Lecturer, DISA
pcsdisa@nus.edu.sg

Lesson Objectives



Why information systems are vulnerable to destruction, error, and abuse?



Framework for securing IS



Examine tools and technologies for safeguarding information systems

Learning Resources



- Textbook (read before class)
 - Read chapter 8
- Any Other Material
 - Shared on Canvas for this week

Case Study

Read the case study from textbook on –Cyberattacks in the Asia-Pacific Target the Weakest Link: People

Identify:

- a. The problem
- b. Key Reasons for problem escalation in the region
- c. Responses from various organizations
- d. What do you understand by these 2 terms: Security and Controls?

Note: be ready to share your thoughts

Case Study

Problem:

The Asia-Pacific (APAC) region has become a major target for cyberattacks of sophisticated phishing techniques that appear legitimate

- Geopolitical tensions and weaker cyber regulations increase APAC cyber risk
- Singapore's pervasive technology creates a vulnerable "digital lifeline"
- Cyberattacks often target people rather than technical systems
 - E.g., In July 2018, hackers broke into Singapore's healthcare system and stole 1.5 million health records, including those of the prime minister
 - Others: SIA, OCBC, DBS (Hongkong)

Key Reasons:

Region's increased focus on IT and the Internet has made it a target

- Pervasive technology, geopolitics, and weaker cyber regulations
- Highly networked Asian companies dealing with numerous external partners
- *Internal threats*: Most data leaks in Asia (~56%) come from internal sources, including company staff and executives)

Case Study

Organizational Response:

- SIA acted quickly to warn customers and informed them via both traditional and social media channels
 - Created a feedback page on its official website to advise customers about the authenticity of emails purportedly from SIA
- OCBC issued warning to customers
 - Offered certain security guarantee of refunds (subject to T&Cs)
- Educate customers about security practices
 - Manage data breaches proactively

Security: refers to the policies, procedures, and technical measures used to prevent unauthorized access, alteration, theft, or physical damage to information systems.

Controls: are methods, policies, and organizational procedures that ensure the safety of the organization's assets, the accuracy and reliability of its records, and operational adherence to management standards.

"In essence, if you operate a business today, you need to make security and control a top priority."

Multiple Incidents

Personal info of 1.5m SingHealth patients, including PM Lee, stolen in Singapore's worst cyber attack



1 of 3 About 15 million patients, including Prime Minister Lee Hsien Loong and a few ministers, have had their personal data stolen. Some 160,000 people also had their outpatient prescriptions stolen.

Source

Nearly 470 people lose at least \$8.5m in phishing scams involving OCBC Bank



Victims received unsolicited SMSes purporting to be from the bank, claiming that there were issues with their banking accounts. ST PHOTO: CHONG JUN LIANG

Source

330,000 S'pore Starbucks customers' data leaked, info sold online for \$3,500



The data breach compromised Starbucks customers' personal information, including their names, home and e-mail addresses. PHOTO: ST FILE

Source

Multiple Incidents

Software update

Hackers had gained access through a SolarWinds software called Orion, using malware disguised as a software update.

SolarWinds provides network-monitoring and other technical services to thousands of organisations around the world, including most Fortune 500 companies and government agencies in North America, Europe, Asia and the Middle East. The firm has an office in Suntec City.

According to reports, more than 18,000 private and government users had downloaded this tainted software update, which reportedly allowed hackers to monitor internal e-mails at some of the top agencies in the US.

Agencies that may have been impacted include the Centres for Disease Control and Prevention in the US, as well as the country's State Department and the Justice Department.

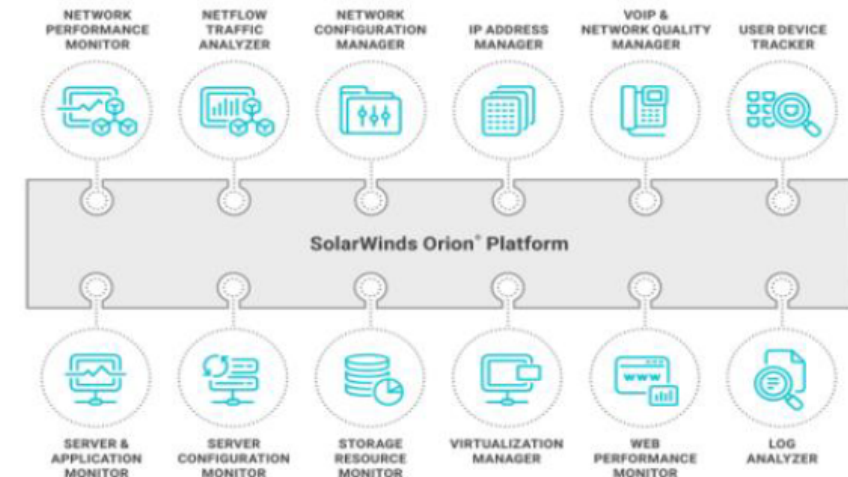
It has been reported that last year, SolarWinds was alerted to the fact that anyone could access its update server by using the password "solarwinds123", exposing a jarring vulnerability in the firm's system.

Source: <https://www.straitstimes.com/singapore/no-reason-to-believe-singapore-was-a-target-in-fireeye-hack-csa>
<https://www.fireeye.com/blog/threat-research/2020/12/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor.html>



Orion Platform

This powerful platform makes it easy to monitor, analyze, and manage the complete IT stack in one place.

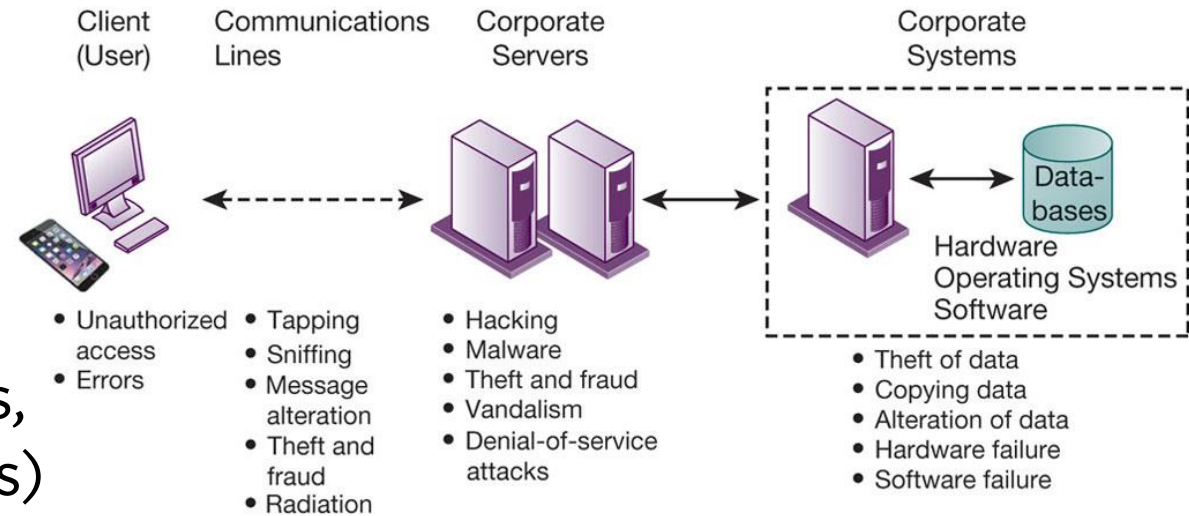


Business Value of Security and Control

- Failed computer systems can lead to significant or total loss of business function
- Firms now are more vulnerable than ever
 - Confidential personal and financial data
 - Trade secrets, new products, strategies (E.g., [2014 Sony Pictures hack](#))
- A security breach may cut into a firm's market value almost immediately (E.g., [2017 Equifax data breach](#))
- Inadequate security and controls also bring forth issues of liability

Why Systems are Vulnerable

- Accessibility of networks
- Hardware problems (breakdowns, configuration errors, damage from improper use or crime)
- Software problems (programming errors, installation errors, unauthorized changes)
- Disasters, human errors
- Use of networks/computers outside of firm's control
- Loss and theft of portable devices

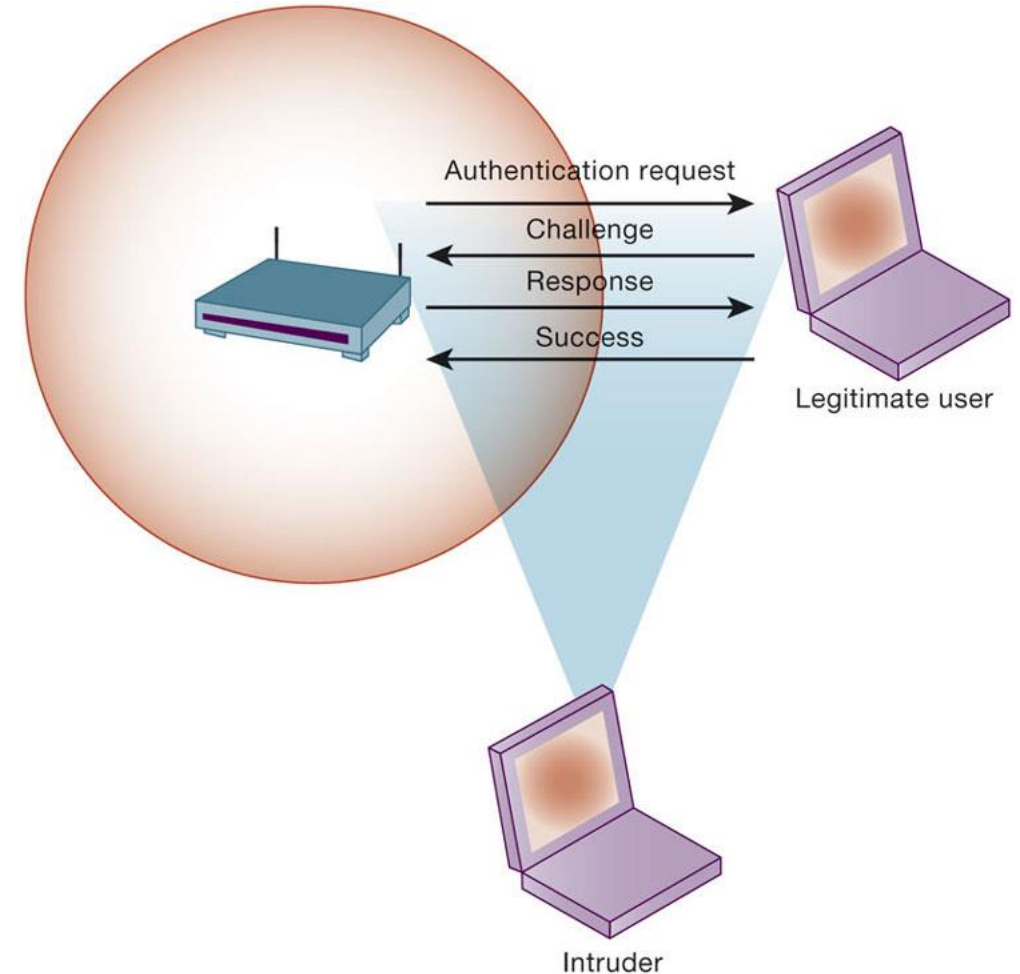


Internet Vulnerabilities

- Network open to anyone
- Size of Internet means abuses can have wide impact
- Use of fixed Internet addresses with cable/DSL modems creates fixed targets for hackers
- Unencrypted VOIP
- E-mail, P2P, IM
- Interception
- Attachments with malicious software
- Transmitting trade secrets

Wireless Security Challenges

- Radio frequency bands easy to scan
- SSIDs (service set identifiers)
- Identify access points, broadcast multiple times, can be identified by sniffer programs
- War driving
 - Eavesdroppers drive by buildings and try to detect SSID and gain access to network and resources
 - Once access point is breached, intruder can gain access to networked drives and files
- Rogue access points



Malicious Software: Viruses, Worms, Trojan Horses, and Spyware

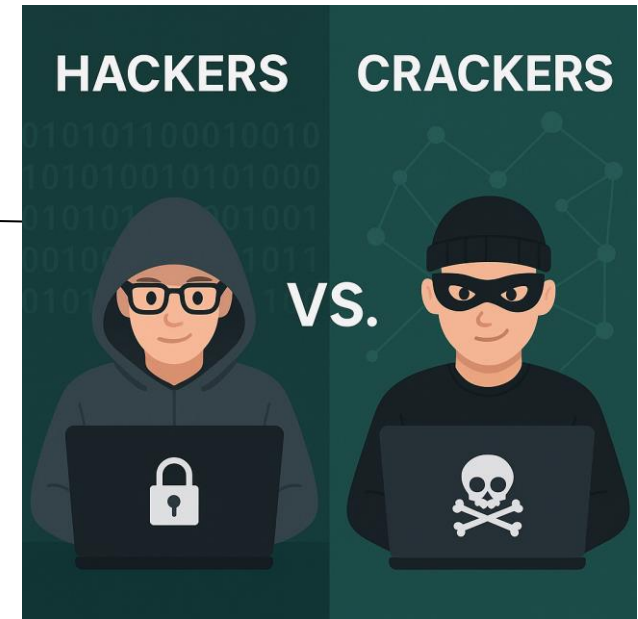
- Malware (malicious software)
- Viruses
- Worms
- Worms and viruses spread by
 - Downloads and drive-by downloads
 - E-mail, IM attachments
- Mobile device malware
- Social network malware

- Trojan horse
- SQL injection attacks
- Ransomware
- Spyware
 - Key loggers
 - Other types
 - Reset browser home page
 - Redirect search requests
 - Slow computer performance by taking up memory

Hackers and Computer Crime

- Hackers vs. crackers
- Activities include:
 - System intrusion
 - System damage
 - Cybervandalism
 - Intentional disruption, defacement, destruction of website or corporate information system
- Denial-of-service attacks (DoS)

- Spam
- Identity theft
 - Phishing
 - Evil twins
 - Pharming
- Click fraud
- Cyberterrorism
- Cyberwarfare



Other Causes

Internal Threats

- Security threats often originate inside an organization
- Inside knowledge
- Sloppy security procedures
 - User lack of knowledge
- Social engineering
- Both end users and information systems specialists are sources of risk

Software Vulnerability

- Commercial software contains flaws that create security vulnerabilities
 - Bugs (program code defects)
 - Zero defects cannot be achieved
 - Flaws can open networks to intruders
- Zero-day vulnerabilities
- Patches
 - Small pieces of software to repair flaws
 - Patch management

The C.I.A. Triad

- The three key characteristics of information that make it valuable to an organization:
- **Confidentiality**: Limiting access to information only to authorized users
 - Information classification
 - Secure document (and data) storage
 - Application of general security policies
 - Education of information custodians and end users
 - Cryptography (encryption)

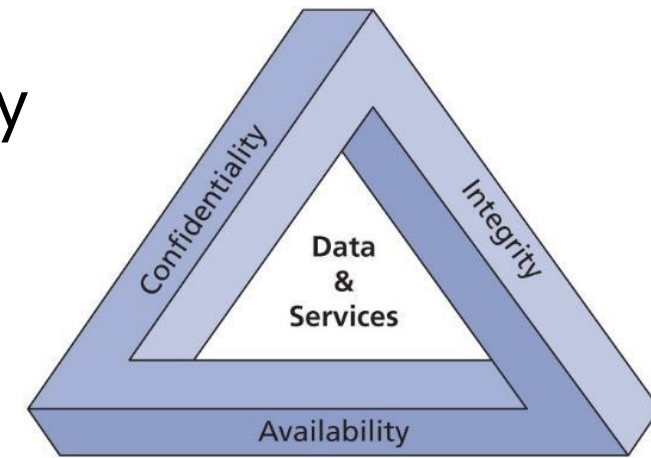


Figure 1-3 The C.I.A. triad

The C.I.A. Triad (cont.)

- **Integrity**: Ensuring data is whole, complete, and uncorrupted
 - The integrity of information is threatened when it is exposed to corruption, damage, destruction, or other disruption of its authentic state
 - e.g., secret key + hash functions
- **Availability**: An attribute of information that describes how data is accessible and correctly formatted for use without interference or obstruction

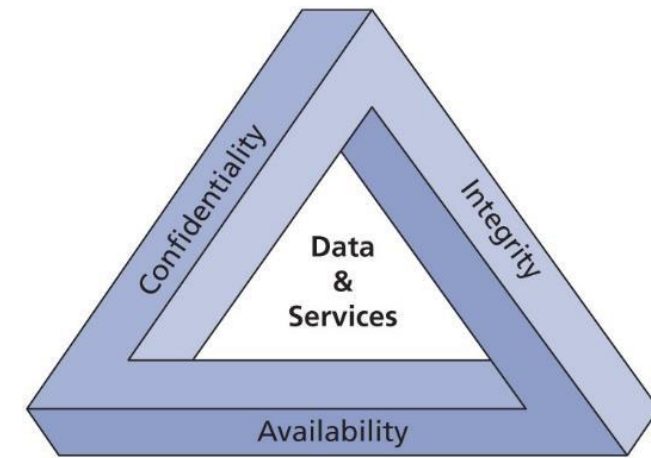


Figure 1-3 The C.I.A. triad

Balancing Security and Access

- Perfect information security is impossible – It's a process, not a goal
- Security should be a balance between protection and availability
- Trade-offs must be considered between:
 - Security controls and user convenience
 - Cost of security vs. value of protected assets
 - Acceptable risk vs. business operations

Example

In 2023, Citibank implemented new anti-scam measures in its mobile app that restrict access if risky permission settings are detected on users' devices. While this improves security, it creates friction for legitimate users who must adjust their settings.

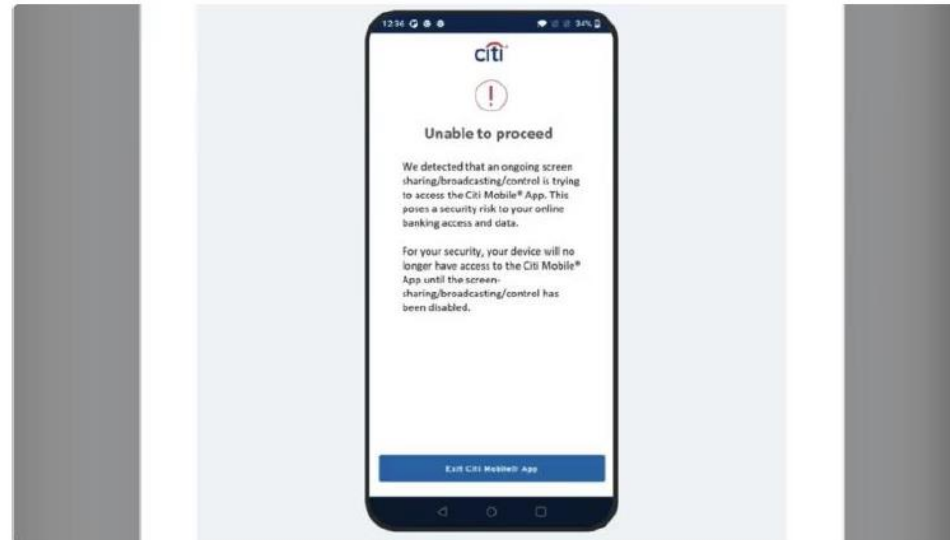
Citibank's new anti-scam measure restricts users' access to app if risky permission settings detected

Citibank says restrictions to the Citi Mobile App will be lifted once the risky permission settings have been disabled.

17 Sep 2023 03:45PM
(Updated: 18 Sep 2023 06:54PM)

SINGAPORE: A new anti-scam feature on Citibank's mobile app will restrict users' access if it detects risky permission settings on other apps.

In an email sent to Citi Mobile App users on Friday (Sep 15), Citibank said the security update was part of ongoing efforts to provide a safe and secure banking environment.

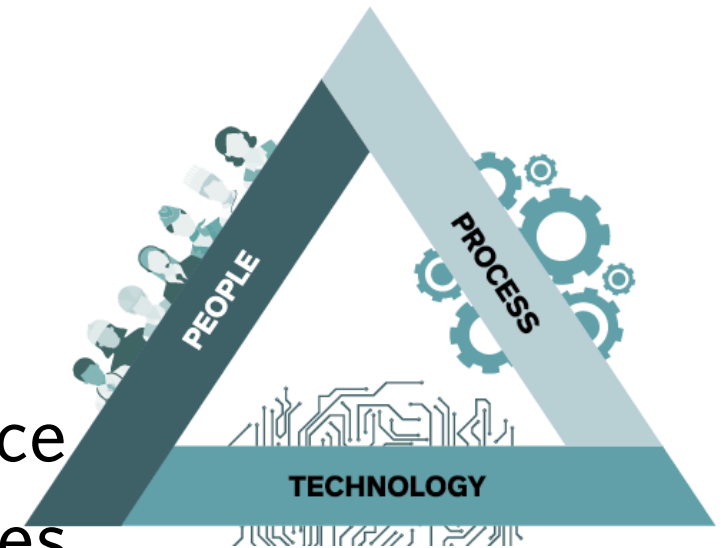


Screengrab of an email sent by Citibank to Citi Mobile® App users about its new anti-scam feature.

Source: <https://www.channelnewsasia.com/singapore/citi-bank-mobile-app-anti-scam-measure-restrict-access-if-risky-permission-settings-detected-3777016>

People, Process, and Technology

- Security is only as strong as the weakest link
- All three elements must work together
- People as the Weakest Link
 - Susceptible to social engineering
 - May bypass security controls for convenience
 - May lack awareness of security best practices
 - Insider threats (malicious or accidental)



Technology alone cannot solve security problems. People and processes are equally important.

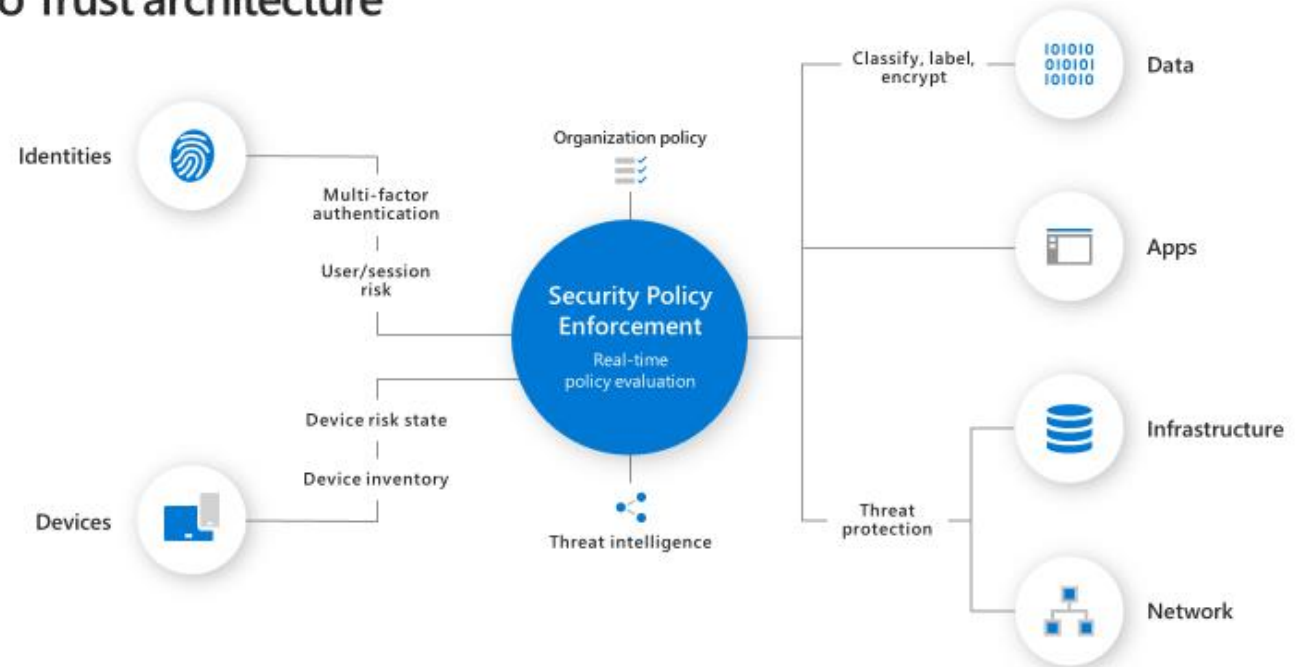
Access Control Principles

- **Need to know:** Users only have access to information required for their role
 - Limits potential damage from compromised accounts
 - Reduces insider threat risks
- **Least privilege:** Users have minimum permissions necessary to perform tasks
 - Implies need-to-know
 - Reduces attack surface
- **Zero-trust:** Never trust, always verify
 - No one is trusted by default from inside or outside the network
 - Continuous verification regardless of user location
 - Micro-segmentation of resources

Microsoft Zero Trust Architecture

- **Verify explicitly:** Always authenticate and authorize based on all available data points
- **Use least privileged access:** Limit user access with Just-In-Time and Just-Enough-Access (JIT/JEA)
- **Assume breach:** Minimize blast radius and segment access. Verify end-to-end encryption and use analytics to detect threats

Zero Trust architecture



Source

Supplier Risk Management

Ensuring service providers and IT suppliers don't create unacceptable risks:

1. **Planning**: Define requirements and risk tolerance
2. **Due Diligence Selection**: Evaluate security practices, certifications, past incidents
3. **Contracting**: Establish clear SLAs, security requirements, incident response procedures
4. **Monitor and assess**: Regular security assessments, performance reviews
5. **Termination**: Secure data transfer/deletion, revoke access, transition plan

Example: AWS provides clear **Service Level Agreements** that specify uptime guarantees, service credits for failures, and detailed definitions of responsibilities for both AWS and customers.

Risk Management

5 basic risk control strategies:

1. **Defense**: Apply safeguards to eliminate/reduce risk
 - Example: Installing firewalls and anti-malware software
2. **Transference**: Shift risk to other areas or entities
 - Example: Purchasing cyber insurance policies
3. **Mitigation**: Reduce impact if a risk materializes
 - Example: Implementing incident response plans
4. **Acceptance**: Acknowledge and accept the risk
 - Example: Accepting minor risks where controls cost more than potential loss
5. **Termination**: Remove the asset from operating environment
 - Example: Shutting down a vulnerable legacy system

Tools and Technologies for Safeguarding Information

- Firewalls and intrusion detection systems
- Encryption (data at rest and in transit)
- Identity and access management systems
- **Multi-factor authentication**

- Security information and event management (SIEM)
- Endpoint protection platforms
- Email security gateways
- Data loss prevention tools

A defense-in-depth strategy employs multiple security technologies in layers.

Activity

Find out:

- What kinds of security problems do fraudulent emails pose? How serious are they?
- What management, organization, and technology factors are responsible for phishing problems?

Summary

1. Security is a continuous process requiring vigilance and adaptation
2. People, process, and technology all play critical roles in security
3. Security responsibilities must be clearly defined, especially in cloud environments
4. Balance is needed between security controls and usability/accessibility
5. Risk can never be eliminated, only managed appropriately
6. Organizations must stay current with evolving threats and regulations

Next

Enhancing Decision Making